# CA1 - Open Source Firewalls Assignment

**Roman Oleinikov**
**Pavlo Panchenko**

*Department of Informatics School of Informatics and Cybersecurity*

*TU Dublin Blanchardstown Campus*
*Dublin 15.*

**Word Limit for Assignment: 2500** **Actual Word Count: 2271**

**Course : Cybersecurity**

**Module : Network Security**

**01/11/2025**

## Table of contents


Roman Oleinikov part ..... 3
1. Introduction ..... 3
2. Firewall configuration ..... 3
3. Tests ..... 4
3.1 SSH and HTTP/HTTPS ..... 4
3.2 PING ..... 4
3.3 NMAP ..... 4
3.4 Dirbuster ..... 5
3.5 Slowloris DOS attack ..... 5
Pavlo Panchenko part ..... 6
1. Introduction ..... 6
2. Firewall configuration ..... 6
3. Tests ..... 7
Conclusion ..... 7
References ..... 8

## Roman Oleinikov part

## 1. Introduction

For this project Endian firewall community release v3.3.2 has been used. Endian is Linux based UTM stateful firewall based on the iptables which the firewall interacts with to analyze packets. Firewall can be accessed through the console on the machine itself or via ssh connection, but a more convenient way is to use the web-based GUI. Endian uses Zone-Based-Policy, offering Green, Red, Orange and Blue zones. For the following project LAN-to-Internet design was used with Red zone as external network and Green zone as internal network.

## 2. Firewall configuration

Firewall was configured in the "default" routing mode with two active interfaces:

Eth0 – which is used for the "Green zone" of the firewall. In this zone is located our Metasploitable web-server, which will act as our target system. Additionally, since the Xubuntu virtual machine has been created on this side of the network, it was necessary to continue firewall configuration from the web page instead of the terminal on the firewall virtual machine itself.

Eth1 – is configured as the uplink between the external network (Red zone) and the Green zone. On the external side of the network a Kali Linux virtual machine is created to run the test on the firewall rules.

Firewall was the following way:

1. System access to the firewall itself was disabled for all zones except for the green. This way only machines from the green zone would be able to connect to the firewall via ssh, https or other protocols.
2. As the Metasploitable web server uses the http protocol and not the https, the only connection allowed from the Red zone to Green zone was http on port 80. Our goal is to make sure that the user from the outside network can only access the web page of the server, and nothing more.
3. DHCP server has been enabled in firewall services so the machines inside the Green zone would get their IP addresses from the firewall. Also, the Intrusion prevention system has been activated, and logging service was activated as well.

## 3. Tests

### 3.1 SSH and HTTP/HTTPS

As it was mentioned, no ssh connection was allowed from the Red zone. In this scenario we run an ssh command form our Kali Linux with known credentials of firewall root user and regular user on the web server:

“ssh root@192.168.100.1

ssh: connect to host 192.168.100.1 port 22: Connection timed out”

The same thing happened after the attempt to ssh as a user to the web server. So it can be seen that this part of firewall rules is configured correctly. It also can be seen in the log files how the TCP packets on port 22 were dropped by the firewall.

Then via the web browser in Kali Linux we attempted to access web pages of our firewall and web server.

As we configured our firewall to drop all the system access attempts from the Red zone – the firewall would again drop all our TCP packets.

However, we were easily able to access the Metasploitable web page, as it was configured accessible in our firewall rules.

### 3.2 PING

Several attempts were made to ping both firewall interfaces and the web server from our Kali VM, but all of them were dropped by the firewall.

### 3.3 NMAP

What we wanted to test next was the intrusion prevention system on the firewall. To test how it works we run the following nmap commands:

1. “nmap -sS -p1-1000 -Pn 192.168.10.2”

Idea of using this command is to check if Endian IPS will detect nmap scanning tool which uses the stealth scan. The scan successfully showed the open port and service running on it, and in log files there were no messages from the IPS about discovering the nmap activity, only regular messages from the firewall about dropping packets.

2. “nmap -Pn -sV --script vuln 192.168.10.2”.

The idea of this command is to give us information on the potential vulnerabilities of the host, and possible ways of exploiting them. We ran this command with and without the IPS system to see if there would be any difference in the firewall behavior and the command output.

This time IPS did better as it was able to successfully discover the Nmap Scripting Engine. Moreover, as a part of its output, nmap offered a list of possible sqli for queries. After we attempted to run one of them, IPS was able to successfully recognize the sql scan and warn about it.

However, the difference in the output of the nmap scans with and without IPS turned on was confusing. With IPS on, output of nmap was able to find more http-csrf vulnerabilities, but at the same time it was not able to tell that the web server is vulnerable to the CVE-2007-6750 (Slowloris DOS attack). On the other hand, less http-csrf vulnerabilities were found with the IPS off, but the scan was able to find the vulnerability to Slowloris attack.

Most likely reason for such a result is that IPS would try to confuse the scanner by altering the content of packets so that some of the nonexistent pages would be displayed as existing. This way threat actors may spend more time finding existing vulnerable directories. Also, it is clear that IPS recognized the nmap scanning tool and prevented it from finding out about potentially serious vulnerabilities, so it is most likely that creating false positives during scanning is part of its rules.

### 3.4 Dirbuster

To double check that our theory is correct, a dirbuster tool was used to enumerate through the web server. And with the IPS on we immediately got the following warning: “The web server you are testing is returning inconsistent pages for the dir files that do not exist.” With IPS off this message was not displayed. Now we can confidently say that the IPS of Endian firewall can successfully recognize various scanning tools and create false-positive responses to confuse them, giving more time to react to the potential attack.

### 3.5 Slowloris DOS attack

While the IPS was off, nmap scan showed that the web server is vulnerable to CVE-2007-6750 (Slowloris DOS attack). So we decided to run this exploit in the metasploit console to see if it would be successful against our firewall.

Test was extremely successful – the web server could not be accessed from other machines in the green zone, and the IPS could not recognize the attack, even though a vulnerability was reported back in 2009.

Several attempts were made to prevent the attack from succeeding, including the activation of HTTP proxy and enabling disabled IPS rules. But none were successful, as it seems like the custom snort rule should either be downloaded or created and then added to IPS ruleset, as the means offered by the firewall were not enough.

There is always a possibility that we missed some configuration option, but after examining the firewall documentation we could not find and apply it.

It is fair to say that this is not as critical as it may seem, as the http protocol is less used nowadays, and the IPS prevented nmap scanner from learning about this vulnerability.

## Pavlo Panchenko part

## 1. Introduction

In this project, I used pfSense, a fairly popular and user-friendly firewall based on FreeBSD. pfSense runs on the pf (Packet Filter) engine, which is responsible for packet filtering and routing. Essentially, it's a powerful system that allows you to build your own router with flexible security settings.
You can manage pfSense through the console, connecting directly to the device or via SSH, but the web interface is most often used—it's intuitive and allows you to quickly change settings without having to work from the command line.

pfSense divides the network into zones, most often WAN and LAN (internal network).

To implement the project, I prepared three virtual machines. The first machine, "Firewall," was created using a pfSense ISO file. The second machine, "Target" (or "Victim"), was deployed using a Windows 10 ISO file. The third machine, "Attacker," used a Kali Linux ISO file.

## 2. Firewall configuration

On the "Firewall" machine, I configured two network adapters: Host-Only (local area network) and WAN (internet access). This provided local area network access for the "Target" machine and internet access for the "Attacker" machine. When I launched the pfSense installation, I immediately appreciated the user-friendly setup wizard: the setup process took less than a minute, and after a quick installation, a menu with sixteen configuration options appeared.

Having selected item 2 – IP configuration, I began to configure the firewall parameters.

Using the selected menu item, I configured the network parameters: assigned static IP addresses and specified address ranges for the WAN and LAN interfaces.

It looked like this:

WAN (wan) -> em0 -> v4: 192.168.96.120/24 (DHCP range 192.168.96.121 – 192.168.96.150)
LAN (lan) -> em1 -> v4: 192.168.204.100/24 (DHCP range 192.168.204.100 – 192.168.204.150)

Using a Windows machine, I was able to access the pfSense graphical interface via a browser. Using this interface, I created firewall rules that restrict unwanted activity from the "Attacker" machine, thereby protecting the local network and controlling access to "Target" resources.

## 3. Tests

### SSH

After setting up the rules, I tested their operation via SSH. Attempts to connect to the "Target" machine via SSH from the "Attacker" machine were unsuccessful.

using the command
"ssh -oHostKeyAlgorithms=+ssh-rsa \
-oPubkeyAcceptedKeyTypes=+ssh-rsa \
pasha@192.168.204.128"
I got "ssh: connect to host 192.168.204.128 port 22: Connection refused"

This effect is observed due to the configuration of rules that block TCP port 22 for traffic from the attacker's subnet, as a result, SSH connection attempts with "Attacker" fail.

### PING

While testing the rules, I checked the nodes' availability using ping. Attempted requests from the "Attacker" machine to the "Target" machine were blocked according to the firewall policy.

### NMAP

To assess open ports and services on the hosts, I used nmap, which confirmed that SSH ports and other unauthorized services were not accessible to the "Attacker" machine.

I used the command "nmap -sS -p1-1000 -Pn 192.168.204.128"

After waiting for two minutes, I received the following output:
"Host is up
All 1000 scanned ports on 192.168.204.128 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 201.37 seconds"

The result shows that the host is reachable, but all the TCP ports checked are in the filtered state - most likely, the packets are blocked by a firewall, which is why Nmap did not receive a response. In practice, this means that the firewall effectively hides services from the attacker's subnet.

## Conclusion

Both Endian and pfSense firewalls use Zone-Based policies and showed solid level of protection by successfully enforcing their rules on the routed traffic. Both firewalls offer range of services such as DHCP server, proxy servers

and IPS. However, Endian IPS test showed mixed results, as while it effectively recognized and confused scanning tools, it was not able to mitigate the DoS attack, which was rather known even 10 years ago, which shows us that Endian community release may be less flexible and up to date compared to pfSense firewall.

Another issue worth mentioning is that pfSense is a better supported firewall with regular updates, while Endian community edition lacks updates a lot. The last pfSense update was released in 2025, and update on Endian firewall was released in 2023. It will soon be more than two years without any updates, which may be critical as new vulnerabilities and exploits are discovered every month.

To sum up, both firewalls were successful in applying their rules to the network traffic and providing configured services, but the psSense seems to be a slightly better choice due to its more active community and more frequent updates.

## References


Endian S.r.l. (n.d.). *Endian Firewall Community documentation*. Endian Community. Retrieved from https://docs.endian.com/6.7/utm/

Netgate. (n.d.). *pfSense documentation*. Netgate Documentation Portal. Retrieved from https://docs.netgate.com/pfsense/en/latest/

Koromicha. (2024, July 25). *Install and configure Endian Firewall on VirtualBox*. Kifarunix. Retrieved from https://kifarunix.com/install-and-configure-endian-firewall-on-virtualbox/

IritT. (2024, November 3). *PFSense: Comprehensive guide to installation, configuration, and SYN flood attack log analysis: pfSense-CE-2.6.0-RELEASE-amd64.iso*. Medium. Retrieved from https://iritt.medium.com/pfsense-comprehensive-guide-to-installation-configuration-and-syn-flood-attack-analysis-441a5419f467

Nmap.org. (n.d.). *Subverting intrusion detection systems*. In *Nmap Network Scanning: Chapter 10 — Detecting and Subverting Firewalls and Intrusion Detection Systems*. Retrieved from https://nmap.org/book/subvert-ids.html

Nmap.org. (n.d.). *Firewall subversion* [Bypassing firewall rules]. In *Nmap Network Scanning: Chapter 10 — Detecting and Subverting Firewalls and Intrusion Detection Systems*. Retrieved from https://nmap.org/book/firewall-subversion.html